



Play it Safe: Manage Security Risks

CISSP (Certified Information Systems Security Professional)

CISSP 8 security domains

1. Security and Risk management
 - a. security goals and objectives, risk mitigation, compliance, business continuity, and legal regulations
2. Asset Security
 - a. securing digital and physical assets
3. Security Architecture and Engineering
 - a. Optimizing data security by ensuring effective tools, systems, and processes are in place to protect an organizations assets and data.
4. Communications and Network security
 - a. managing and securing physical and networks and wireless communications
5. Identity and Access management
 - a. access and authorization to keep data secure, by making sure users follow established policies to control and manage assets
6. Security assessment and testing
 - a. conducting security control testing, collecting and analyzing data, and conducting security audits to monitor for risks, threats, and vulnerabilities.
7. security operations

- a. conducting investigating and implementing preventative measures.
- 8. software development security
 - a. secure coding processes.

NIST frame work: National institute of standards and technology

Risk Management Framework (RMF)

Prepare: Prepare before a breach occurs

Categorize: develop risk management processes and tasks

Select: Choose, customize, and capture documentation of the controls that protect an org

Implement: Implement security and privacy plans for the org

Assess: Make sure the established controls are implemented correctly.

Authorize: Being accountable for the security and privacy risks that may exist in an org.

Monitor: Be aware of how systems are operating.

NIST Cybersecurity framework (CSF): A voluntary framework taht consists of standards, guidelines, and best practices to manage cyber securirty risk.

Govern: Importance of strong cybersecurity governance across all levels of the organization. It's about establishing and maintaining the structures and processes needed to effectively manage cybersecurity risk.

Identify: The management of cybersecurity risk and its effect on an organization's people and assests

Protect: Protect and org through the implementations of policies, procedures, training, and tools that help mitigate threats.

Dectect: Identifying potential security incidents and improving monitoring capabilites to increase speed and efficiency of detections.

Respond: Proper procedures are used to contain, neutralize, and analyze security incidents and implement improvements

Recover: Returning affected systems back to normal status

NIST S.P. 800-53: A unified framework for protecting the security of information systems within the federal gov.

Security Ethics: Guideline for making appropriate decisions as a security professional

Privacy protection means safe guarding personal information from unauthorized use.

Log: record of events that occur with a system.

Security Information and Event Management tool (SIEM): Centralized application that collects and analyzes log data to monitor critical activities

Playbook: manual that has details about an operational action

Network protocol analyzer (packet sniffer): tool designed to capture and analyze data traffic

Intrusion Detection System (IDS): an application that monitors system activity and alerts on possible intrusions.

Security Posture: an org's ability to manage its defense of critical assets and data, and react to change.

Threat: Any circumstance or event that can negatively impact assets

Risks: Anything that can impact the confidentiality, integrity, or availability of an asset.

Vulnerabilities: A weakness that can be exploited by a threat.

Security Frameworks: Guidelines used for building plans to help mitigate risk and threats to data and privacy.

Security Controls: Safeguard designed to reduce specific security risks

Encryption: the process of converting data from a readable format to an encoded format.

Authentication: Process of verifying who someone or something is.

Authorization: concept of granting access to specific resources within a system.

CIA Triad: A model that helps inform how organizations consider risk when setting up systems and security policies.

Confidentiality: Only authorized users can access specific assets or data

Integrity: The data stays unchanged

Availability: Data is accessible to those who are authorized to access it.

Open web application security project (OWASP) security principles:

Minimize attack surface area: all potential vulnerabilities a threat actor could exploit

Principle of least privilege: users have the least amount of access required to perform their everyday tasks.

Defense in depth: Multiple security controls that mitigate risks and threats.
(email, mfa codes)

Separation of duties: Multiple people should do critical actions, following the least principle.

Keep security simple: avoid unnecessarily complicated solutions.

Fix security issues correctly: Identify root cause, contain the impact, identify vulnerabilities, and conduct tests to ensure that remediation is successful.

Security Audit: A review of an organization's security controls, policies, and procedures against a set of expectations.

Purpose of internal security audits:

- Identify organizational risk

- Assess controls

- Correct compliance issues

Common elements of internal audits:

- Establishing the scope and goals

- Conducting a risk assessment

- Completing a controls assessment

- Assessing compliance

- Communicating results

Audit Questions

- What is the audit meant to achieve?

- Which assets are most at risk?

- Are current controls sufficient to protect those assets?

- What controls and compliance regulations need to be implemented?

Stakeholder communication

- Summarizes scope and goals of audit

- Lists existing risks

- Notes how quickly those risks need to be addressed

- Identifies compliance regulations

- Provides recommendations

Audit Checklist

- Scope of audit

- List assets that will be assessed

Note how the audit will help the organization achieve its desired goals

Indicate how often an audit should be performed

Include an evaluation of organizational policies, protocols, and procedures to make sure they are working as intended and being implemented by employees.

Complete a risk assessment

A risk assessment is used to evaluate identified organizational risks related to budget, controls, internal processes, and external standards.

Conduct the audit

Access the security of the identified assets listed in the audit scope.

Create a mitigation plan

Strategy that is established to lower the risk of potential costs, penalties, or other issues that can negatively affect the organization's security posture.

Communicate results to stakeholders

Provide detailed report of findings, suggested improvements needed to lower the organization's level of risk and compliance regulations and standards the organizations need to adhere to.

Security information and event management (SIEM): Centralized location, application that collects and analyzes log data to monitor critical activities in an organization.

Log: a record of events that occur within an organization's systems and networks.

Firewall logs: Record of attempted or established connections for incoming traffic from the internet. It also includes outbound requests to the internet from within the network.

Network logs: Record of computers and devices that enter and leave the network. It also records connections between devices and services on the network.

Server Logs: Record of events related to services such as websites, emails, or file shares. It includes actions such as login, password, and username requests.

Metrics: Key technical attributes, such as response time, availability, and failure rate, which are used to assess the performance of a software application.

Splunk Enterprise: A self-hosted tool used to retain, analyze, and search an organization's log data to provide security information and alerts in real-time.

Splunk Cloud: A cloud-hosted tool used to collect, search, and monitor log data.

Chronicle: a cloud-native tool designed to retain, analyze, and search data.

Playbook: A manual that provides details about any operational action.

Playsbooks ensure that people follow a consistent list of actions in a prescribed way.

Incident Response: An organization's quick attempt to identify an attack, contain the damage, and restore.

Incident Response playbook phases:

Preparation: before incidents occur, mitigate potential impacts on the organization by documenting, establishing staffing plans, and educating users.

Detection and analysis: Detect and analyze by implementing defined processes and appropriate technology.

Containment: Prevent further damage and reduce immediate impact of incidents.

Eradication and recovery: Completely remove artifacts of the incident so that an org can return to normal operations.

Post incident activity: Document the incident, inform org leadership, and apply lessons learned.

Coordination: report incidents and share information throughout the response process, based on established standards.